

网络空间四要素:载体(设施)资源(数据)主体(用户)形式(操作) **PDRR 模型:**防护/检测/恢复/响应 **P2DR 模型:**防护/检测/响应

网络扫描技术:用网络扫描软件对特定目标进行试探性通信以获取目标信息的行为。**目的:**主机扫描:识别目标主机的工作状态(开/关机),端口扫描:--端口状态(监听/关闭),OS 识别:---OS 类型,漏洞扫描:--系统可能存在的漏洞。

主机扫描:向目标主机发送探测数据包,根据是否收到响应来判断主机的工作状态。**ICMP Echo,ICMP Non-Echo:**IP 异常的 IP 数据报首部错误的分片。具体过程:ICMP Echo:请求-响应->目标主机运行;ICMP Echo:请求-未响应->目标主机未开机;ICMP Non-Echo 询问报文/差错报告报文等。异常的 IP 数据报首部(参数错)-参数问题 ICMP 报文/无响应->运行/未开机;IP 包填充错误字段-目标主机反馈 ICMP 目的不可达;缺少 IP 分片无法重组-反馈分片重组超时/无响应-运行/未开机;**TCP Connect 扫描**尝试同目标端口建立正常的 TCP 连接 成功/失败-开放/关闭;优点稳定可靠不需特殊权限;缺点扫描方式不隐蔽会被服务器记录。**SYN 扫描** SYN-SYN+ACK-RST->端口开放 SYN-RST->端口关闭 优点很少有系统记录这种行为;缺点需管理员权限才可构造这种 SYN 包。**FIN 扫描** FIN-无回复->端口开放 FIN-RST->端口关闭 优点不是 TCP 建立链接的过程较隐蔽 缺点与 SYN 扫描类似 也需构造专门的数据包 只适用于 Unix 系统的目标主机 win 总是回复 rst **UDP 扫描** 向 UDP 端口发包若监听则无响应若关闭则返回 ICMP_PORT_UNREACH 错误 **IDS 与扫描** 所有 IDS 都能准确地检测出扫描但是若对同一主机不同端口分布式扫描且间隔时间长则无法监测。**IPV4** 1.无认证机制 • 无消息源认证 • 无完整性认证 2.无加密机制 • 无机密性 • 泄露拓扑信息 3.无带宽控制 • DDos 攻击 **IPV6 过渡方案** 1.双协议栈 2.隧道 3.网络地址转换 NAT **IPV6 安全** 1.4-6 过渡技术的安全风险 2.无状态地址自动配置的安全风险 3.6 中 PKI 管理系统的安全风险 4.6 编址机制的隐患 **RIP 协议安全:**不支持认证 且使用不可靠的 UDP 协议传输安全性差 在无认证保护时,易伪造 RIP 路由更新信息,并向邻居路由器发送,伪造内容为目的网络地址、子网掩码地址与下一跳地址 防范措施: 1.路由器某些接口配置为被动接口,停止向它所在的网络广播更新报文,但可接收其他路由器的更新报文。2.配置路由器的访问控制列表,只允许某些源 IP 地址的路由更新报文进入列表。**OSPF 安全** 最大年龄攻击 序列号加一攻击 最大序列号攻击 重放攻击 篡改攻击 **最大年龄攻击** LSA (链路状态通告) 最大年龄 1h 攻击者持续插入导致最大年龄设置的 LSA 导致网络混乱和 **DOS 序列号+1 攻击** 根据 LSA 序号判断是否是旧的 LSA 序列号大 LSA 新 持续插入大 LSA 序列号报文产生序列号竞

争导致网络不稳定和 DOS **最大序列号攻击** 发送最大序列号的网络设备再次发送报文前要求其他设备也将序列号重置 OSPF 停 15mins,攻击者插入最大序列号的 LSA,触发初始化 **重放攻击** hello 报文重放攻击 LSA 报文重放攻击 **数字大炮** 利用 BGP 路由由正常工作中的路由表更新机制制造震荡效应 **TCP 协议** 连接劫持 TCP 包中的源/目的端口,Seq,Ack 正确即可被正确接收。原来的 TCP 连接会因计数器不匹配而断开连接。**DNS** 一.协议脆弱性 ①域名欺骗 1.事务 ID 欺骗伪装 DNS 服务器提前给客户发送与查询数据报 ID 相同的响应数据报 2.缓存中毒 A 向解析器 R 请求查询百度的 IP 地址, R 将查询转向百度授权域名服务器,攻击者在响应回到 R 前伪造大量解析地址为 IP2 的响应包给 R, R 很难解析来源响应的真实性, DNS 会丢且很难响应首个包后的响应②网络通信攻击 二.实现脆弱性 ①算法错误②非随机报文 ID③BIND 漏洞 三.操作脆弱性 ①域名配置攻击②域名注册攻击③信息泄露 **IPSec 的组成-协议组成** IPSec 把 IP 通信过程分为协商(认证身份 生成会话密钥)和数据交互两阶段 **IPSec 处理**-外出处理 trans 层数据包流入 IP 层, IP 层检索 SPD 数据库,判断为包提供哪些服务。可能有:丢弃、绕过安全服务(加 IP 头,分发 IP 包)、应用安全服务(已有 SA 返回 SA 指针、还没 SA 则调用 IKE 建立)进入处理收到 IPSec 包后根据安全策略检查:丢弃、应用安全服务(若 SA 未建立也丢弃)否则传给上层协议,若 IP 包中含 IPSec,则从 IP 包中提取三元组(SPI,目标地址,协议)检索,由协议值交给 AH 或者 ESP 处理,处理完后在 SPD 中查询验证 SA 使用是否合适。**AH 运行模式** 传输模式 AH 头插入 IP 头之后传输层协议(或者其他 IPSec 协议)之前 **AH 和 NAT 的冲突** AH 验证整个 IP 包(可变字段除外)故源/目的 IP 地址不可修改否则会被检测。然而若其经 NAT 网关,其源/目的 IP 变,造成验证失败。隧道模式 AH 插入原始头部前再增加一个新的 IP 头,和 NAT 的冲突也存疑,该模式下 AH 可单独使用也可和 ESP 嵌套使用 ESP 传输模式 IP 后, TCP 头和数据被 ESP 头尾包裹,整体为验证区域,去掉 ESP 头为加密数据,ESP 验证数据放在 ESP 验证数据之后。加密不含 SPI 和序号字段,不含验证数据,不含 IP 头故无冲突。ESP 隧道模式 保护 IP 包,对整个 IP 进行加密 ESP 头插入原始 IP 前,然后再加新 IP 头,ESP 尾在数据之后,ESP 验证数据在尾部之后。**IKE 交换模式** 第一阶段主模式/积极(野蛮)模式(建立 IKE SA 是其他交换的前提) 第二阶段快速模式(为 IPSec 协商安全服务)

PKI 系统组成 CA (核心) 证书库 证书撤销处理系统 PKI 应用程序接口 CA 的任务 验证标识身份 审批发放更新验证证书 证书资料信息管理 产生发布撤销证书列表 证书归档 密钥

归档 历史数据归档 CA 的职责 确保 CA 用于签名证书的非对称密钥的质量 确保安全性 确保唯一性。证书 密钥管理媒介 权威电子文档 证明主题身份及其公钥 用 CA 私钥签名 **证书主体公钥产生方式** 用户自己生成密钥对 公钥传 CA 保证公钥的可验性与完整性 CA 替用户生成密钥对,将私钥传递给用户,保证机密可验完整 **证书撤销** 废止原因:私钥泄密 从属变更 终止使用 CA 出现问题 撤销原因:CA 知证书细节不实等 **撤销机制** 公布撤销证书列表 CRL (由 CA 私钥签名) 公布在目录中 由 CA 决定 证书验证 验签 验有效期 确认未撤销 使用证书的 APP SSL 电子邮件 虚拟专用网。**SSL** 将 Web 浏览器定向到 Web 服务器的一个另外不同的端口上 会话中所有信息都被加密 用证书确定身份 **安全的电邮** 数字签名 用私钥创建签名 将证书同邮件一起发送 保密 先获得接收者证书,再用公钥加密后发送 **虚拟专用网** 像私有网络一样使用公共网络 信息加密 确定机器身份 终端向对方提交证书并确定有私钥 **证书分发:**协议内部分发 使用库分发 **协议内部分发证书** 电子邮件签名(证书公钥与邮件一起发送) 客户端 SSL (浏览器与其他客户 APP 在服务器下通过协议发送客户证书) **库分发证书** 电邮加密 (LDAP 目录) 服务器端 SSL 认证(本地证书库找 CA/目录服务器查 CA)

Dos 拒绝服务攻击:由于错误的配置或者软件的弱点导致的/利用合理的服务请求来占用过多的服务资源。**Teardrop 攻击:**利用异常的数据分片导致接收方在处理分片数据时崩溃,也称为“碎片攻击”

向受害者发送偏移地址重叠的 UDP 数据包分片 **重叠分片攻击:**目的不是 DoS,而是穿透防火墙。重叠时有的以后来的数据为主,有的则是后来的覆盖之前的。前提条件:防火墙重组数据时与受害者主机不同。**通过分片导致防火墙或 IDS 的拒绝服务:**必须缓存已到的分片,重组完再检测,则可发送大量无法构成完整数据报的分片占据 CPU 与存储单元。**Land 攻击:**原是一段 C 程序,其功能是向受害者发送 TCP SYN 包,而这些包的源 IP 地址和目的 IP 地址被伪造成受害者的 IP 地址,源端口和目的端口也是相同的(端口必须是激活的),目标系统在收到这样的包以后可能会挂起、崩溃或重启。**TCP SYN 包:**连接请求。导致接收服务器向它自己的地址发送 SYN-ACK 消息,结果这个地址又发回 ACK 消息并创建一个空连接,每一个这样的连接都将保留直到超时掉。**循环攻击:**两个都会产生输出的端口之间建立连接以后,两个端口间将会有大量的数据包产生,导致拒绝服务。如 Echo Chargen 攻击 攻击者只需向 A 系统的 UDP Echo 端口发送一个好像来自于 B 系统的 UDP Chargen 端口的 UDP 包,则在 AB 系统的这俩端口间将不停地产生 UDP 包。**SYN 风暴攻击(直接型)**发送大

量 SYN 报文,但对服务器的 SYN+ACK 应答报文不作应答,即三次握手的第三次握手无法完成,造成服务器维护大量的半连接列表,消耗服务器半连接资源(一般系统的上限为 1024,超过此数则不接受新的连接请求)的攻击方式。需伪造地址,一方面逃避追踪,另一方面为了攻击能成功.在未修改攻击主机 TCP 协议栈的情况下,其系统会自动对 SYN-ACK 做出响应,降低攻击效果。**NTP DDos (DRDoS)** 利用 monlist 进行攻击,发送 234B 回复 482B,有 600 个客户端按 6 个 IP 分割最多有 100 个响应包,则为 482*100=48200B 回复报文约是原报文的 206 倍且用 UDP 很容易伪造源地址。NTP 服务器 123 号端口。**SSDP DDOS6 个步骤** 1.攻击者进行扫描寻找可以用作放大因子的即插即用设备。2.发现联网设备后,创建所有发出响应的设备的列表。3.使用目标受害者的欺骗性 IP 地址创建 UDP 数据包。4.使用僵尸网络通过设置某些标志(比如 ssdp:rootdevice 或 ssdp:all),向每个即插即用设备发送一个欺骗性发现数据包,并请求尽可能多的数据。5.每个设备都会向目标受害者发送回复,其数据量最多达到攻击者请求的 30 倍。6.目标从所有设备接收大量流量,因此不堪重负,可能导致对正常流量拒绝服务。两种典型僵尸网络架构 1.基于 IRC2.基于 P2P **DOS 攻击的作用** 瘫痪目标 SYN Flood 攻击可以用于 IP 劫持、IP 欺骗等 使某些安全设备(如防火墙)失效 重启系统,使漏洞利用、更改的配置生效、提升权限 瘫痪目标后,假冒目标(如 DNS) **检测**:根据异常流量来检测(Cont) Dos 产生控制信息与攻击时网络通信 在 IDS 中加入以下规则以检测 Dos 攻击 1.大量的目标主机域名解析:DDoS 攻击前域名服务器会接收到大量的反向解析目标 IP 主机名的 PTR 查询请求。2.极限通讯流量:当 DDoS 攻击一个站点时,会出现明显超出该网络正常工作时的极限通信流量的现象。可以在主干路由器端建立 ACL 访问控制规则以监测和过滤这些通信。3.特大型的 ICMP 和 UDP 数据包:一般 UDP<10B,ICMP 在 64-128B 间 长度明显大得多的数据包很有可能就是 DDoS 攻击控制信息,主要含有加密后的目标地址和一些命令选项。4.不属于正常连接通信的 TCP 和 UDP 数据包。5.数据段内容只包含文字和数字字符 **响应** 对付风暴型 DDoS 攻击的方案主要有四种: 1.丢弃恶意分组的方法保护网络; 2.在源端控制 DDoS 攻击; 3.追溯 (Traceback) 攻击的源端,然后阻止它发起新的攻击; 4.路由器动态检测流量并进行控制。最有效的对抗风暴型 DDoS 的方法是: **流量清洗**。DDoS 攻击阻断过程一般包括攻击监测和判断、流量牵引、清洗过滤、流量回送四个关键环节 **防范** 限制带宽 终端防御 入口过滤:只允许必要的通信 完全阻止是不可能的,防范可减少被攻击的机会 多用用户权限 Linux 将全部的特权授予了 Root 管理员

当设置了 set-user-ID 标志位时,真实用户 ID 仍是运行进程用户的 ID,而有效用户 ID 变成了当前运行文件的所有者的 ID。如 tip 程序为 uucp 拥有,实际 usrid=我们的 usrid,有效 usrid=uucp,保存设置 usrid=uucp。tip 执行 setuid(getuid()) 因为 tip 不是超级用户进程,所以仅改变有效 usrid,此时得到实际 usrid=我们的 usrid 有效 usrid=我们的 usrid(改变) 保存设置用户 id=uucp 执行完毕后 tip 执行 setuid(uucpuid)得到原来的那个。**缓冲区溢出**:重写堆栈中储存的 EIP 地址的内容,以使程序跳转到指定 shell code 处执行。使用不安全的 strcpy 和 strcat 等导致 **堆栈的作用** 1.堆栈在子程序调用的时候用来传递参数 2.堆栈用来保存子程序的返回地址 3.堆栈用来保存子程序中的变量 1.Nop 填充 降低计算返回地址的难度 2.Shellcode 衍生出需要的 shell 3.重复返回地址填充增加覆盖原来返回地址的概率。**Printf 工作原理** 遍历 若非格式化参数 输出 若是 采取相应动作 若 printf(str)则错误 错误的源码使得系统将用户的输入作为具有控制功能的格式化串,从而可以通过构造输入来进行攻击。IDS 检测任何损害或企图损害系统的保密性、完整性或可用性行为的一种网络安全技术。监视受保护系统的状态和活动/采用误用检测或者异常检测的方式。前提是非法合法行为可区分 解决提取描述行为特征的数据 高效判断行为的特质。术语: **警报 异常 网络入侵特征数据库 构造数据包 自动响应** (如重配路由器/防火墙 发送 reset 包切断连接) **蜜罐 (Honeypot)** 模拟存在漏洞的系统,为攻击者提供攻击目标 **安全策略 感应器 分类** 入侵检测模型主要有两种:即滥用检测(利用已知的系统缺陷和入侵方法进行入侵活动的检测精度高 难以应对未知)和异常检测(建立目标系统及其用户的正常活动模型,然后基于这个模型对系统和用户的实际活动进行审计)。**基于主机的数据源** 操作系统审计纪录 (由包含在操作系统软件内部的专门的审计子系统产生用于反映系统活动的信息集合,按照时间组织成一个或者多个审计文件,每个审计文件由审计记录组成 **问题**:不兼容 包含无关信息 过于精简 **特点**:提高信源可信度 从 OS 级获取信息可得到系统事件的细节 为 IDS 实现精确模式匹配奠定基础 入侵者很难改变审计日志)和系统日志(反映各种系统事件和系统设置的文件 常存储在系统未经保护的目录中,并采用文本方式存储 相对容易遭到篡改 需要对日志备份 **特点**:直观人性化 可能无法得到或者解释审计日志 使得 IDS 可以从不同角度反映同一件事) **基于网络的数据源** 方式:网络监听 对保护对象性能影响较小 网监器对 net 中 usr 透明的 降低本身受攻击的可能 也可发现对主机的基于 net 协议的攻击 与受保护主机的 OS 无关。相关数学模型: 试验/平均值标准差/多变量/马氏过

程/时序 **CIDF 规格文档** 四部分: 体系结构 规范语言 内部通讯 程序接口 **CIDF 互操作** 配置 (发现并交换)/语法 (识别交换的数据)/语义 (理解~) 互操作 **组件** 事件产生器 事件分析器 事件数据库 响应单元 **通信层次** GIDO 层 (对传输消息格式化)/消息 (加密认证并可靠传输)/传输 (不在 CIDF 规范 可用很多现有传输机制实现) **编写 snort 规则** 规则头 (规则行为/协议/源目的 IP/子网掩码/源目的端口)和规则选项 (报警信息/异常包信息如特征码和签名) **规则文件的语法** 规则 变量定义 Include 预处理加载 输出加载 **简单模式匹配的缺点** 总能避开 攻击的本质不在于特殊字符 本质在于检测病毒有效否 **根本问题** 通过简单变换即可逃避检测 通过更新规则应对代价太大 层次的两种观点 检测与保护不交叉(OS 无关可靠性好存在冗余工作 IDS 负担重)/紧耦合(简洁高效) **响应类型** 被动响应(记录/报告问题)主动响应 (用自动/用户指定的方式阻断攻击 针对入侵者 修正系统 收集详细信息) 入侵响应小结: 即时(发生)/及时(完全检测出)/本地长期/全局长期 **堡垒主机** 阻塞点 **双宿主机** 接内网外网 **防火墙局限性** 限制/关闭有用的网络服务/对内网攻击无能为力/不能防范不经防火墙的攻击/不完全透明/不能完全组织传输(效率太低/不能防范数据驱动式攻击/被动的防护手段 **包过滤防火墙** 路由器实现 对数据包检查 由过滤规则决定转发或丢弃 配置为双向 基于 IP 包头信息和规则执行 **六项要求** 1.设备存有包过滤规则 2.到达端口时分析 IP UDP TCP 报中的字段 3.包过滤规则的存储顺序与应用顺序相同 4.一条规则阻止包传输则被禁止 5 一条允许或者接收则通行 6.不满足任何一条则阻塞 屏蔽主机/屏蔽子网 动态包过滤/状态包检查 SPI/会话结束的判定与临时条目的删除 **NAT 作用** 隐藏内部网络 解决 IP 地址不足 解决地址交迭 负载均衡 **http** 无状态使攻击容易 基于 ASCII 码易了解协议明文信息 HTTP 标准不一致导致新攻击 **cookie** 包含敏感信息如用户名计算机名等 **注入漏洞** SQL 注入 系统调用 shell 调用 **原理** 利用 web app 对特殊字符串过滤不完全的缺陷 大多数 sql 注入发生在 web app 使用输入内容动态拼接 sql 语句访问数据库时 **检测** 整型输入 and 1=1(2)运行正常/异常 字符串型 输入一个单引号异常 输入'and' 1='1(2)运行正常/异常 **防护** 字符串长度验证 对单引号双'下划线百分号等 sql 注释符号转义 对接收参数类型格式化 不拼接 sql 不使用管理员权限的 db 连接 机密信息不明文存放 异常信息少给提示 **XSS 跨站攻击** 防护 服务器端数据校验 **XSS 前提** web 服务接收输入如 url 参数表单字段或者 http 头与 cookie 值 web 程序必须重新显示输入内容 类别 反射式(url 带有恶意攻击代码)/存储式(盗取信息)/DOM 式(改变 html 上的内容)